

ISYS90090 · CYBERSECURITY MANAGEMENT

Security Education, Training and Awareness

Week 8 tutorial · the control that works through people rather than around them.

Tuesday 3 to 5 pm · Thursday 1 to 3 pm

Two overlapping triangles in shades of blue are located in the bottom right corner of the slide, serving as a decorative element.

PART A AND B

Q and A on this week's content

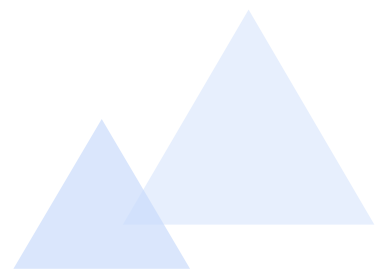
Six questions, eighteen minutes. All of them come off the lecture slides, and all of them are the ones you will need in the second half.

The elements of SETA

	Education	Training	Awareness
Attribute	Why	How	What
Level	Insight	Knowledge	Information
Objective	Understanding	Skill	Exposure
Teaching	Theoretical instruction	Practical instruction	Media
Method	· Discussion seminar · Background reading	· Lecture · Case study workshop · Hands-on practice	· Videos · Newsletters · Posters
Test measure	Essay (interpret learning)	Problem solving (apply learning)	· True or false · Multiple choice (identify learning)
Impact timeframe	Long term	Intermediate	Short term

Table recreated from Guttman, B & Roback, E 1995, An introduction to computer security: The NIST Handbook, Gaithersburg, MD, SP 800-12, p. 145.

The elements of SETA



01 A poster is listed under one of the three columns. Which one, and what does that column say its objective is?

02 Awareness has a short-term impact timeframe. What does that mean for an organisation whose whole program is posters?

The security poster

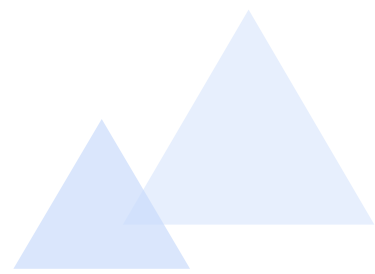
Simple, inexpensive, and easy to do **badly!**

A poster series keeps security on people's minds. Professional posters can be quite expensive, so in-house development is often the better solution — which is what this week's workshop asks you to do.

KEYS TO A GOOD POSTER SERIES

- 01 Vary the content and keep the posters updated
- 02 Keep them simple, but visually interesting
- 03 Make the message clear
- 04 Information on reporting violations (e.g. stats)

The security poster

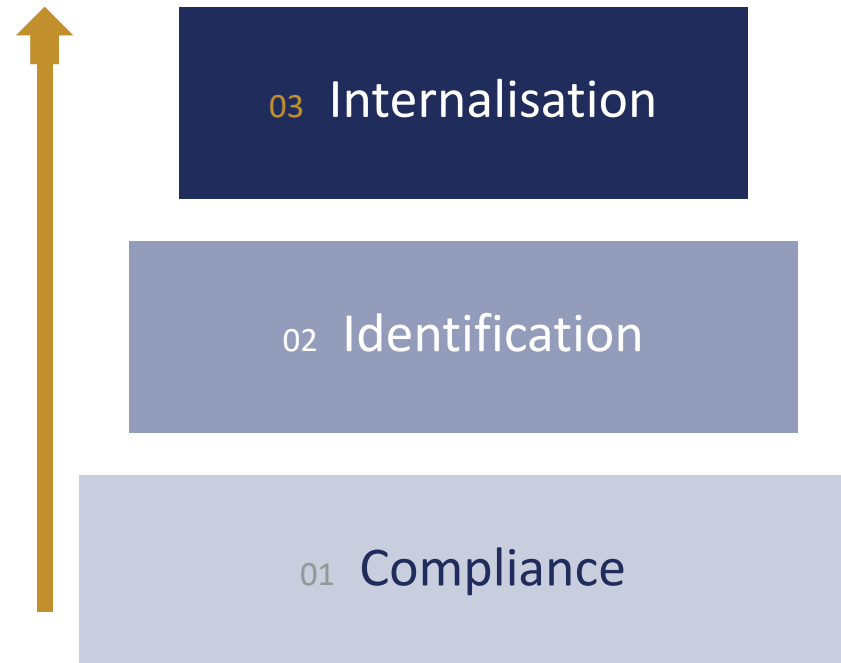


03 The lecture gives four keys to a good poster series. Which of the four is hardest to sustain in an organisation, and why?

04 Training is customised by functional background and by skill level. A poster hangs on a wall. Who is it customised for?

The Kelman Behaviour Change Model

YOU CANNOT SKIP A LEVEL



Internalisation

People protect organisational data the way they protect **their own**.
Autonomous behaviour, without supervision.

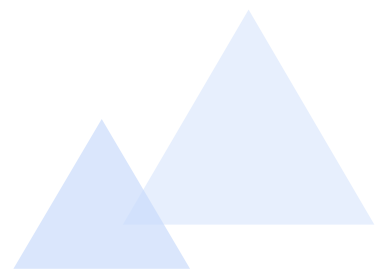
Identification

People follow the practice because they trust and **respect the security function**. Business units collaborate willingly with the CISO office.

Compliance

People follow rules **to avoid punishment**. The change is temporary and superficial, and it needs constant monitoring. The moment supervision goes, so does the behaviour.

Kelman, H.C. (1958). Compliance, identification and internalization: three processes of attitude change. *Journal of Conflict Resolution*, 2(1), 51–60.



Why programs stall

05 A poster that warns of a penalty reaches which of the three levels, and what happens when nobody is watching/monitoring?

06 Why are SETA programs so often ineffective? Which of the four challenges would stop a poster campaign first?

Parting thoughts

Culture eats strategy for breakfast.

Culture is what is routine and acceptable in the organisation, not what is written in the policy or the training program.

THE QUESTION THAT MATTERS

Why are SETA programs so often ineffective?

FOUR CHALLENGES TO TAKE AWAY

It competes for attention

How much training do employees already do every year?

One size does not fit all

Can different generations, or a CEO and an analyst, be trained the same way?

Compliance drives the format

Online training is favoured for compliance reasons, but employees rush through with no intention of engaging.

Doing it properly is expensive

The version that changes behaviour is not the one that fits the budget.

PART C

Horizon, scene 14

Rewind: how Jordan penetrated Horizon's network.

Recent past, London (United Kingdom)

Who is who in the Horizon case

AT HORIZON AUTOMOTIVE

Anders Svensson

Chief Executive Officer

Lena

VP Research and Development

Linus

VP Manufacturing

Kurt

IT Manager

Marcus

Mid level IT Manager

Gustav

HR Manager

Lisa

Corporate Solicitor

Lars

Head of physical security

Carl

Risk assessor

Mikael

Employee

AROUND HORIZON

Emil

Former R and D engineer

Erik

Dealer in performance cars

Patrick Chau

Corporate intelligence consultant

Karim

Independent information security consultant

THE THREAT

Oliver

Spymaster, retired intelligence officer turned mercenary

Jordan

Hacker

John

Representative of FC Design Automotive Industries

Scene 14, what happens

Recent past, London.

Jordan, a hacker, stares at a poster sized sheet on the table in front of him. On it is an organisational chart of Horizon, complete with employee mug shots, handwritten phone numbers, and an IP address for each node. He built it by mapping the firm's digital footprint with hacking tools, emails and social networking sites.

He flips through the personnel profiles and picks out **Mikael**, an employee, as the most trusting of them. He points a denial-of-service attack at Mikael's node and leaves it running for about two hours. Then he picks up a disposable phone, puts on a Swedish accent, and rings him as Ludwig from TeleFon Services. There are problems with the network, he says, and he needs to verify the owner of the machine. Mikael gives his name and his employee ID, 34135.

Jordan scans the chart for IT services and settles on **Marcus**, a mid level IT manager with super user access. He rings him as Mikael: he ran a program off a USB he found in the parking lot, and it came up with a message saying he had been infected by the Tomb Raider. Jordan had already planted a fake notice about that virus on bugtraq. Marcus asks for the employee ID, checks it, and says the virus is not detected by their antivirus suite, so he will contact their antivirus firm, V-Scan.

About an hour later Jordan rings Marcus from a second disposable phone, as V-Scan, and emails the update Marcus is now waiting for. Attached is malware Jordan wrote himself. It opens a remote connection to his computer, and his commands run at super user privileges.

25:00


Who could have stopped Jordan?

Step 1

Write out what Jordan actually did, as a sequence. [TIMELINE]

Use the scene. Number the steps on your board in the order they happened.

Step 2

Pick one named person who could have behaved differently.

Say the one thing that person should have done instead. A specific action, not an attitude.

Step 3

Draw the poster that would have made that person change their behavior.

Aimed at that person, asking for that one action. Say where it hangs, and draw it at the size it will be read from.

One person, one thing that person should have done instead, and a poster that asks for it.

Report back

Three or four zones, ninety seconds each. Photograph your board before it is wiped.

Your spokesperson says three things, in this order.

Who

The person you picked, and the job they do at Horizon.

What

The one thing that person should have done instead.

Poster

What it says, and which wall it hangs on.

Then

Photograph the board.

12 MIN

12:00



Ninety seconds each

Keep to ninety seconds so that every zone gets a turn.

Make the message clear.

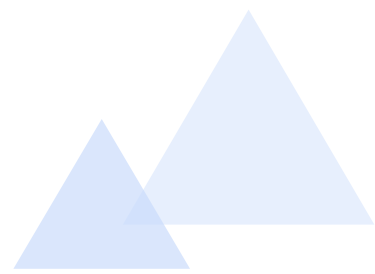


Five minutes

Part C starts on the timer. It runs for forty five minutes and it does not stop in the middle.



Quiz



Your name

Name in CAPITALS, plus your student email. No student numbers.



Declaration

Complete the declaration at the top of the sheet before you start.



Marking

Shade dark. To change an answer, Put one clear line through it and write the letter, shade the correct answer, and write the answer letter at the corner